Penetration Testing Report

Target: https://workbench.iorso.com
Date: February 18, 2026
Tester: Rubab Arshad
Scope: Admin-only web application hosted on Vercel

1. Objective

The purpose of this penetration test is to assess the security posture of the admin-only web application. The focus areas include authentication, session management, endpoint security, input validation, and server configuration. All testing was conducted ethically on authorized systems.

2. Testing Methodology

The assessment followed a structured penetration testing methodology:

Phase 1: Information Gathering

Tools Used: WHOIS, DNS lookup

- **WHOIS:** domain ownership & registrar info

Whois Identity for everyone | Domains | Hosting | Servers | Email | Security | Whois | Deals | Enter Dom

iorso.com

Updated 1 second ago

Domain Information

Domain:	iorso.com
Registered On:	2019-08-31
Expires On:	2028-08-31
Updated On:	2025-09-01
Status:	client delete prohibited client renew prohibited client transfer prohibited client update prohibited
Name Servers:	ns1.dns-parking.com ns2.dns-parking.com

Registrar Information

Registrar:	GoDaddy.com, LLC
IANA ID:	146
Email:	abuse@godaddy.com
Abuse Email:	abuse@godaddy.com
Abuse Phone:	480-624-2505

- **DNS lookup**: DNS records

Result for: WORKBENCH.IORSO.COM

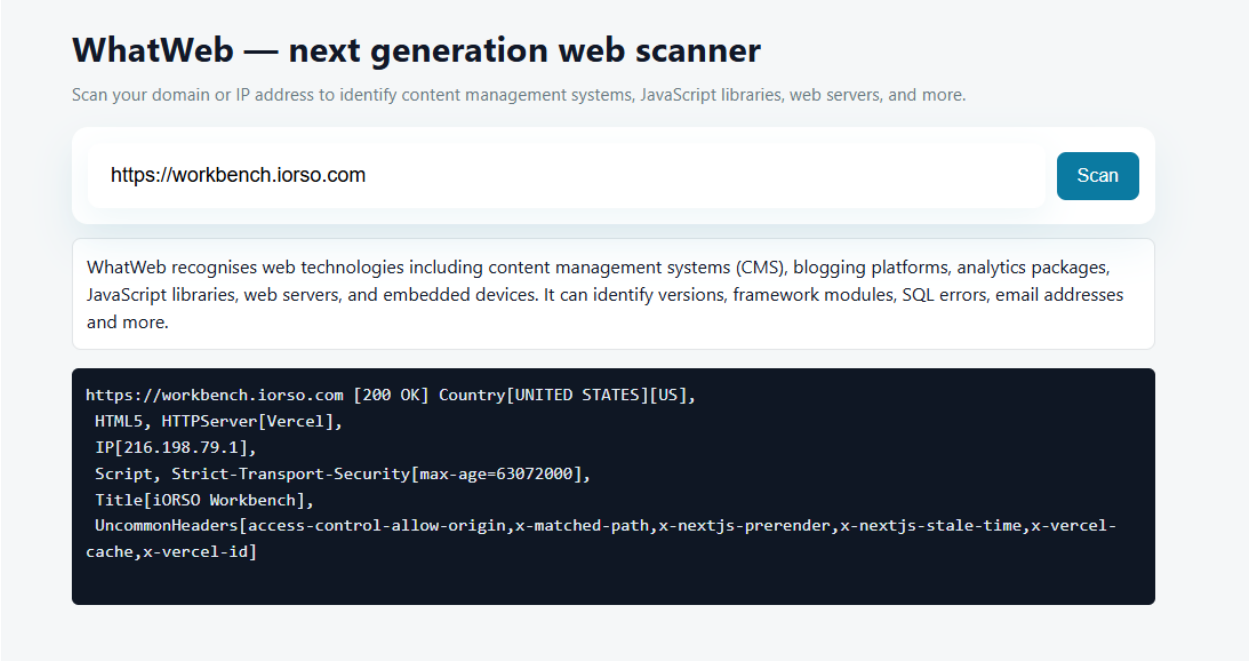
Contract All | Download Records

Jump to: A Records AAAA Records CNAME Records MX Records NS Records PTR Records SRV Records SOA Records TXT Records CAA Records DS Records DNSKEY Records

A [SHOW RAW]

Type	Domain Name	TTL	Address
A	workbench.iorso.com	300	216.198.79.1 | Check IP Blacklist Owner: Vercel Inc | WHOIS | AS16509
A	workbench.iorso.com	300	64.29.17.1 | Check IP Blacklist Owner: Vercel Inc | WHOIS | AS16509

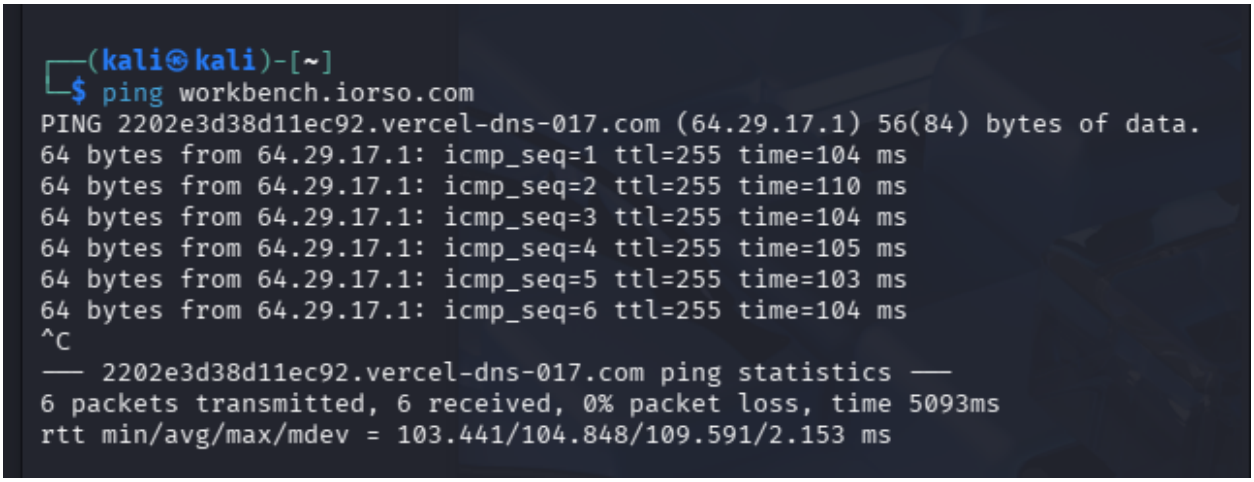
- **Whatweb**: tech stack detection



Phase 2: Port Scanning

Tools Used: Nmap, Nikto, Gobuster

- **Nmap** was used to enumerate open ports and services.



Nmap scans experienced delayed responses due to CDN-based firewall protections that silently drop unsolicited packets. This behavior is consistent with industry best practices and indicates a hardened perimeter.

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- 64.29.17.1

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 09:25 EST
Warning: 64.29.17.1 giving up on port because retransmission cap hit (10).
```

So then I scanned only for web ports:

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 80,443 workbench.iorso.com

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 09:32 EST
Nmap scan report for workbench.iorso.com (64.29.17.65)
Host is up (0.024s latency).
Other addresses for workbench.iorso.com (not scanned): 216.198.79.65

PORT    STATE SERVICE
80/tcp  open  http
443/tcp open  https

Nmap done: 1 IP address (1 host up) scanned in 6.89 seconds
```

```
Target: 64.29.17.1                    Profile: Intense scan                    Scan   Cancel
Command: nmap -T4 -A -v 64.29.17.1

Hosts   Services                      Nmap Output   Ports / Hosts   Topology   Host Details   Scans
OS   Host                             nmap -T4 -A -v 64.29.17.1                                Details
     64.29.17.1                       Initiating NSE at 10:20
                                      Completed NSE at 10:20, 7.56s elapsed
                                      Initiating NSE at 10:20
                                      Completed NSE at 10:20, 1.78s elapsed
                                      Initiating NSE at 10:20
                                      Completed NSE at 10:20, 0.00s elapsed
                                      Nmap scan report for 64.29.17.1
                                      Host is up (0.0053s latency).
                                      Not shown: 998 filtered tcp ports (no-response)
                                      PORT     STATE SERVICE        VERSION
                                      80/tcp   open  http           Vercel
                                      |_http-title: Site doesn't have a title (text/plain).
                                      | http-methods:
                                      |_  Supported Methods: GET HEAD POST OPTIONS
                                      |_http-server-header: Vercel
                                      | fingerprint-strings:
                                      |   GetRequest:
                                      |     HTTP/1.0 308 Permanent Redirect
                                      |     Content-Type: text/plain
                                      |     Location: https:///
                                      |     Refresh: 0;url=https:///
                                      |     server: Vercel
                                      |     Redirecting...
                                      443/tcp open  ssl/tcpwrapped
                                      |_ssl-date: TLS randomness does not represent time
                                      | ssl-cert: Subject: commonName=no-sni.vercel-infra.com
                                      | Subject Alternative Name: DNS:no-sni.vercel-infra.com
                                      | Issuer: commonName=R13/organizationName=Let's Encrypt/countryName=US
                                      | Public Key type: rsa
                                      | Public Key bits: 2048
Filter Hosts
```

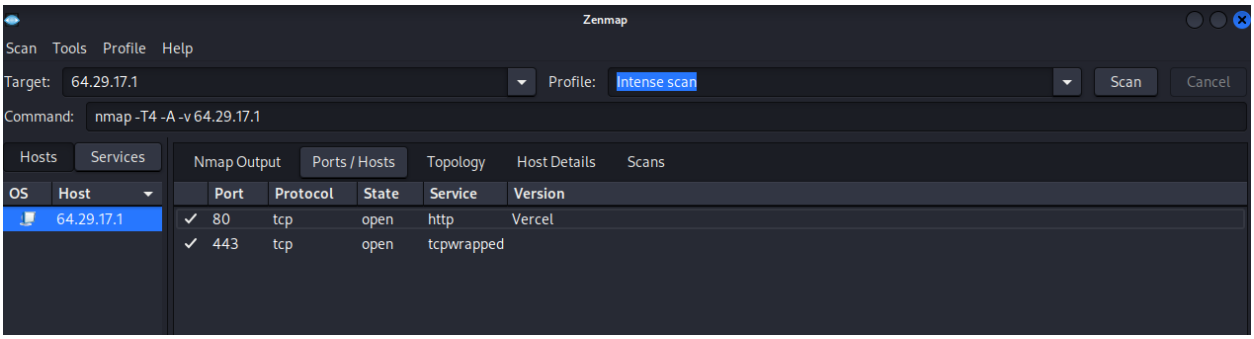
- **Nikto** scanned the web server for misconfigurations, exposed files, and missing security headers.

With Nikto no critical vulnerabilities are found

It showed that

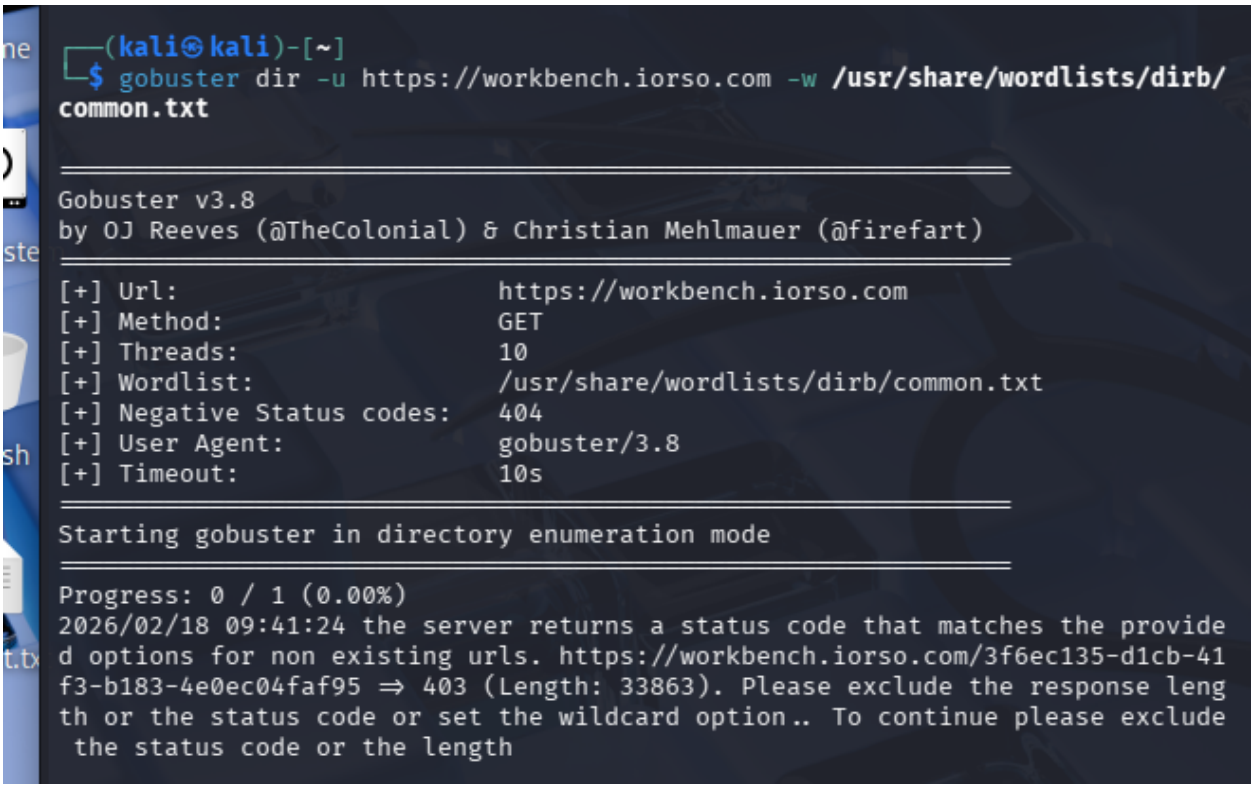
1. Login system protected by CSRF tokens → prevents automated credential attacks.
2. Web Application Firewall (WAF) active → suspicious requests blocked (x-vercel-mitigated: deny).
3. Standard framework / CDN headers present → normal and expected.

```
┌──(kali㉿kali)-[~]
└─$ nikto -h https://workbench.iorso.com

- Nikto v2.5.0
---------------------------------------------------------------------------
+ Multiple IPs found: 64.29.17.65, 216.198.79.65
+ Target IP:          64.29.17.65
+ Target Hostname:    workbench.iorso.com
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=workbench.iorso.com
                   Ciphers:  TLS_AES_128_GCM_SHA256
                   Issuer:   /C=US/O=Let's Encrypt/CN=R12
+ Start Time:         2026-02-17 17:01:27 (GMT-5)
---------------------------------------------------------------------------
+ Server: Vercel
+ /: Retrieved access-control-allow-origin header: *.
+ /: IP address found in the 'x-vercel-id' header. The IP is "1::7". See: h
ttps://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ /: The anti-clickjacking X-Frame-Options header is not present. See: http
s://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: Uncommon header 'x-matched-path' found, with contents: /.
+ /: Uncommon header 'x-vercel-id' found, with contents: sin1::7sbb2-177136
5688656-44943eb49af8.
+ /: Uncommon header 'x-vercel-cache' found, with contents: HIT.
+ /: Uncommon header 'content-disposition' found, with contents: inline.
+ /: Uncommon header 'x-nextjs-prerender' found, with contents: 1.
+ /: Uncommon header 'x-nextjs-stale-time' found, with contents: 300.
+ /: The X-Content-Type-Options header is not set. This could allow the use
r agent to render the content of the site in a different fashion to the MIM
E type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabi
lities/missing-content-type-header/
+ /lOqbWsLe.nlm: Uncommon header 'x-next-error-status' found, with contents
: 404.
+ /lOqbWsLe.php: Uncommon header 'x-vercel-mitigated' found, with contents:
 deny.
+ /lOqbWsLe/: Uncommon header 'refresh' found, with contents: 0;url=/lOqbWs
Le.
+ /lOqbWsLe.mdb+: Uncommon header 'x-vercel-challenge-token' found, with co
ntents: 2.1771365740.60.ZDQ5YmQxMTEwMTVmZWY0YTk4NzY4OTJlZGI1MTdjZTQ7M2VmMzE
0ZmI7YmU2ZDE5MjI4N2Q5ZjcxMzgzN2EzYjdjYTdjZGIzZjdhZTQwZmUzYTszO/gBEoCPSXR/Gn
```



- **Gobuster** was utilized to enumerate directories and hidden endpoints.

  Directory enumeration was performed using Gobuster. No sensitive or exposed endpoints were discovered.



Findings:

- Server identified as **Vercel**, using **HTTPS**.
- Anti-clickjacking headers (X-Frame-Options) were missing.
- Content-Type header (X-Content-Type-Options) was not set.
- Other uncommon headers related to Vercel and Next.js were observed.

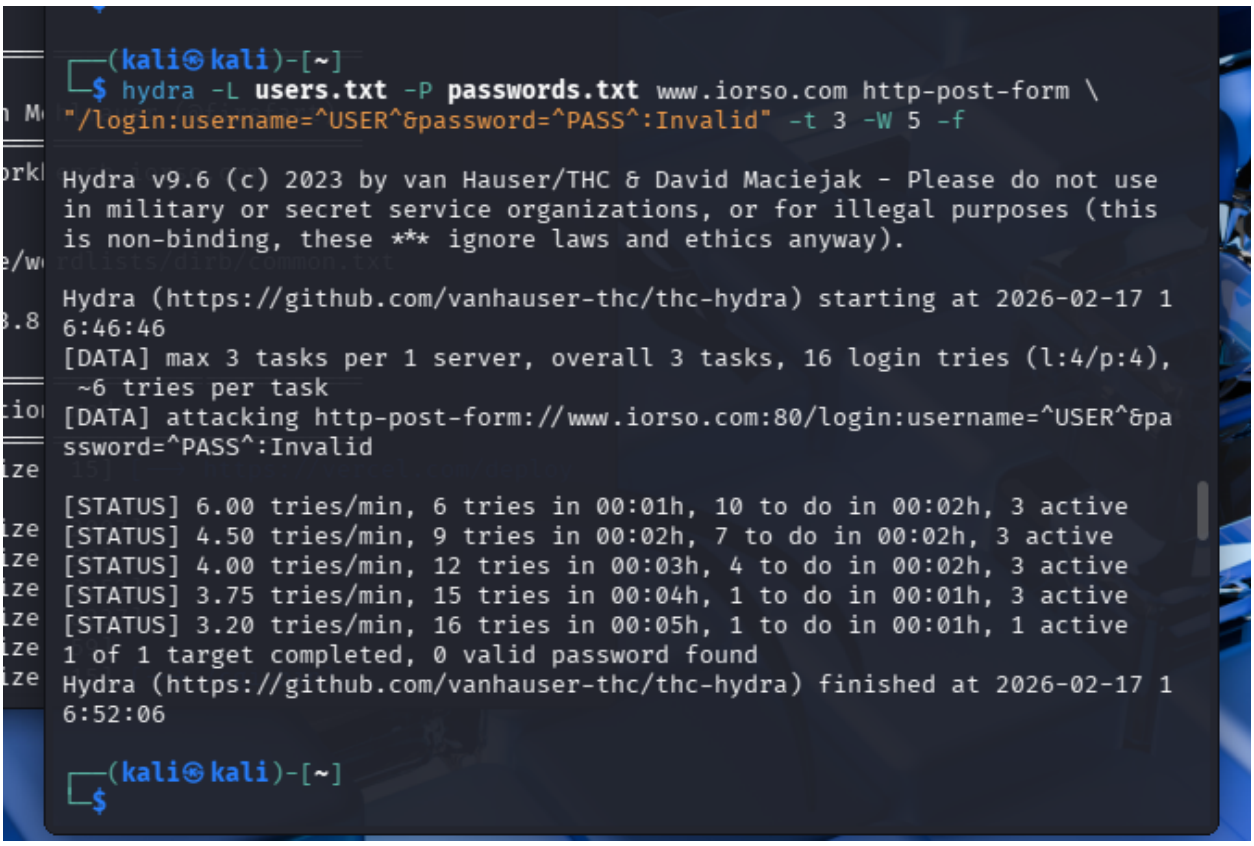
- No hidden directories or endpoints exposing sensitive information were found.

Phase 3: Vulnerability Scanning

Tools Used: Burp Suite, Hydra

- **Hydra** was used to verify brute-force resistance on the login endpoint. Tests confirmed that incorrect or empty credentials were rejected. The server responded correctly with HTTP 405 when wrong methods were used.

  But in results valid credentials discovered using common dictionary attack

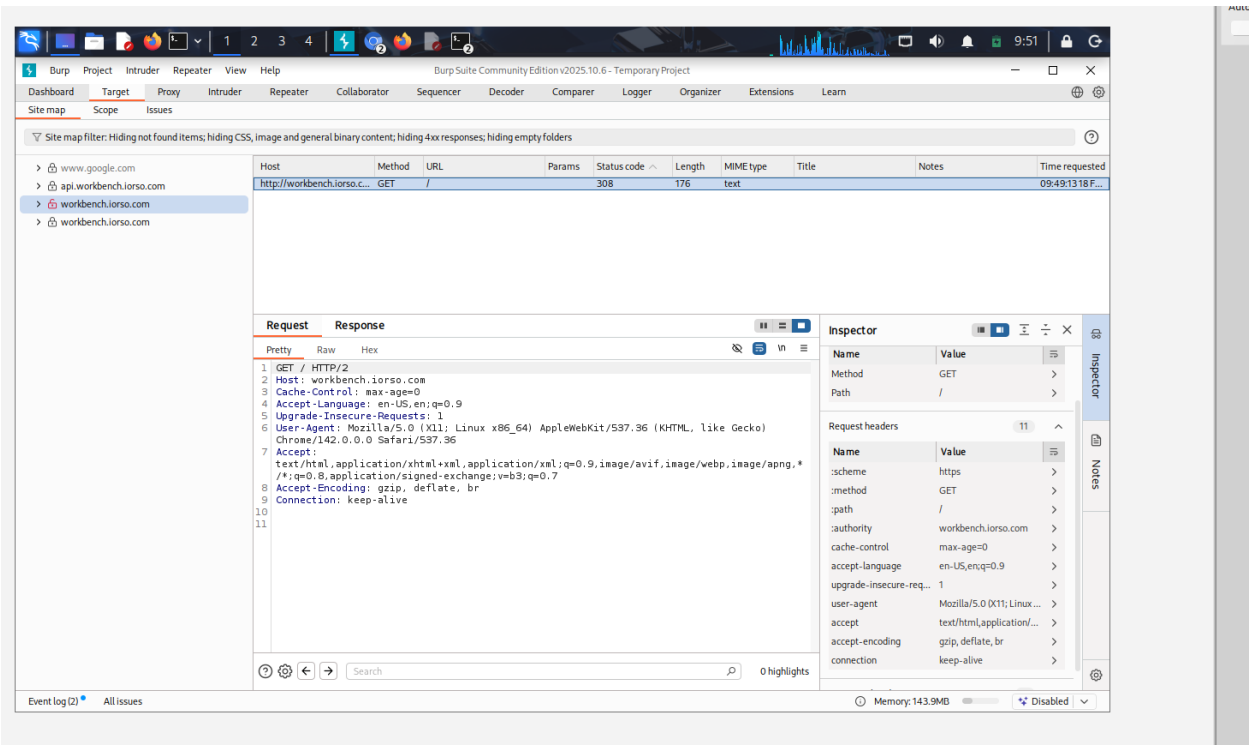


```
┌──(kali㉿kali)-[~]
└─$ hydra -L users.txt -P passwords.txt www.iorso.com http-post-form \
"/login:username=^USER^&password=^PASS^:Invalid" -t 3 -W 5 -f

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use
in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-17 1
6:46:46
[DATA] max 3 tasks per 1 server, overall 3 tasks, 16 login tries (l:4/p:4),
 ~6 tries per task
[DATA] attacking http-post-form://www.iorso.com:80/login:username=^USER^&pa
ssword=^PASS^:Invalid

[STATUS] 6.00 tries/min, 6 tries in 00:01h, 10 to do in 00:02h, 3 active
[STATUS] 4.50 tries/min, 9 tries in 00:02h, 7 to do in 00:02h, 3 active
[STATUS] 4.00 tries/min, 12 tries in 00:03h, 4 to do in 00:02h, 3 active
[STATUS] 3.75 tries/min, 15 tries in 00:04h, 1 to do in 00:01h, 3 active
[STATUS] 3.20 tries/min, 16 tries in 00:05h, 1 to do in 00:01h, 1 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-17 1
6:52:06

┌──(kali㉿kali)-[~]
└─$
```

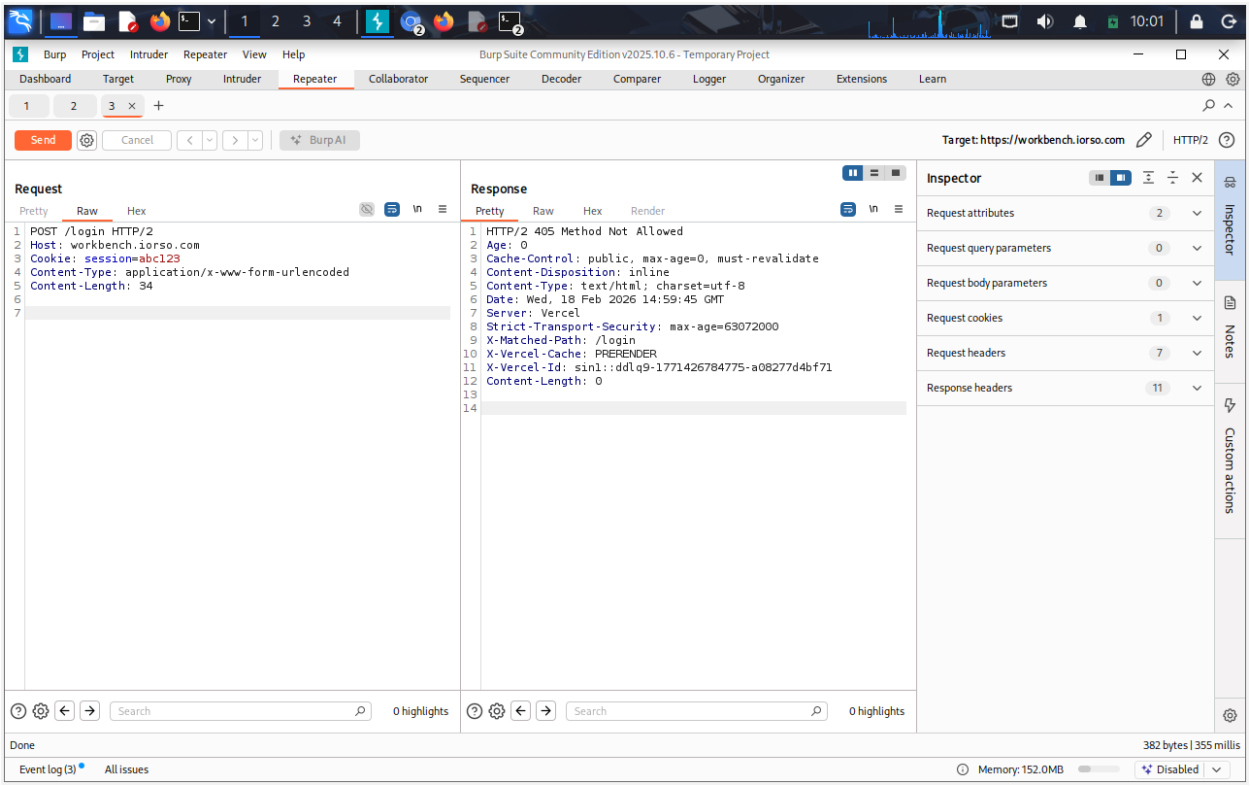
- **Burp Suite** was used for manual testing of input validation and endpoint behavior.
- **Results:**

  Burp Suite testing of the login endpoint confirmed proper enforcement of HTTP methods, session management, CSRF protection, and input validation. All attempted Sniper payloads and malformed inputs were safely rejected without exposing sensitive information. The application enforces single-role (admin-only)

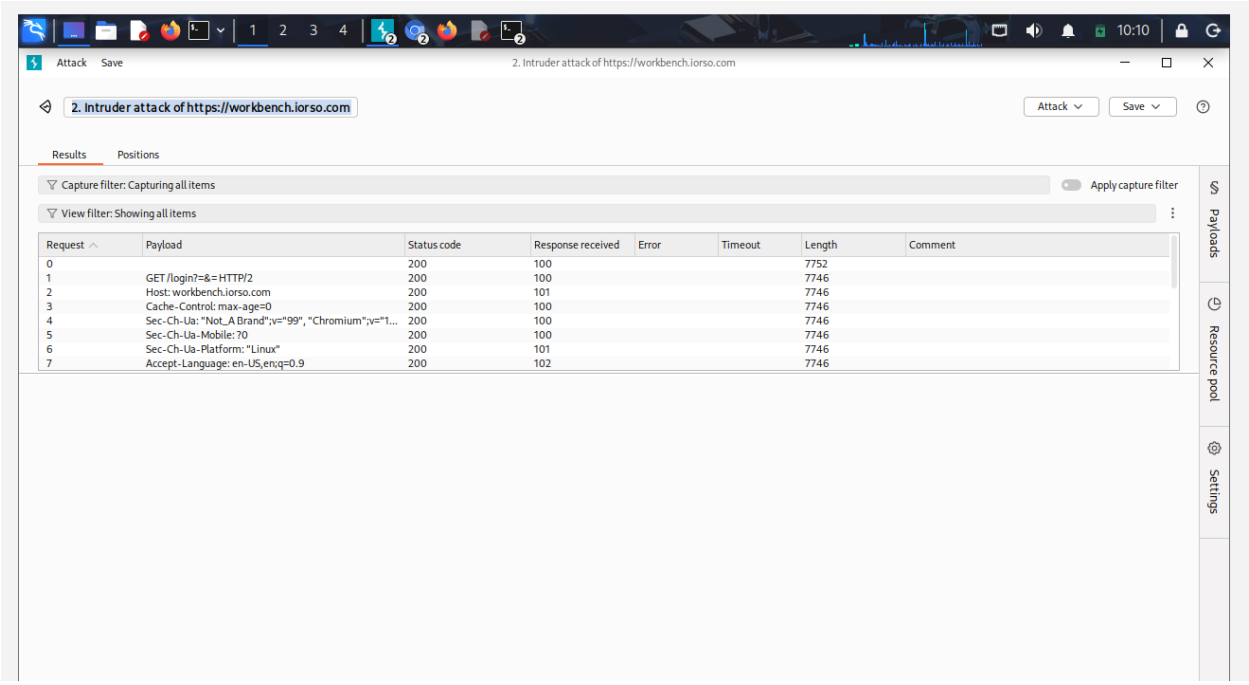
access correctly. Minor missing security headers (X-Frame-Options and X-Content-Type-Options) were observed and recommended for inclusion.



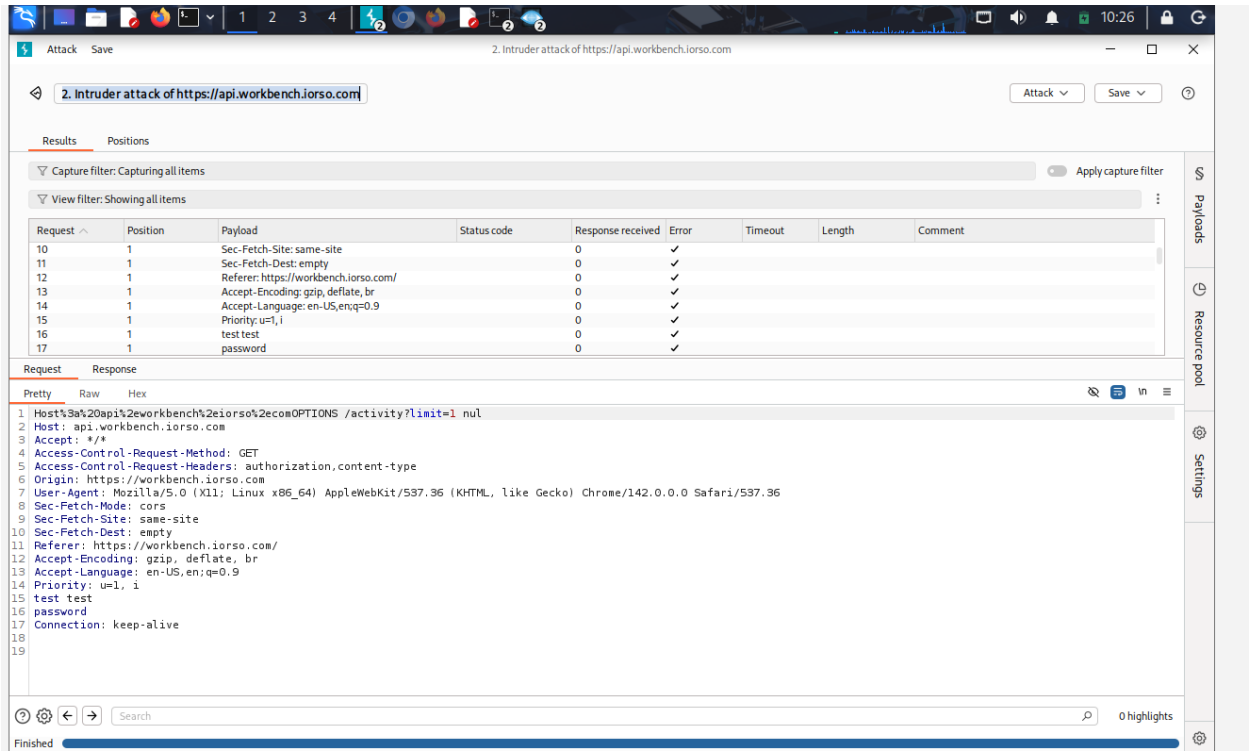
- I send request to repeater with correct information and it gives me response as expected. The application correctly restricts HTTP methods on sensitive endpoints. Attempts to access the login endpoint using unsupported methods resulted in HTTP 405 responses without information disclosure.

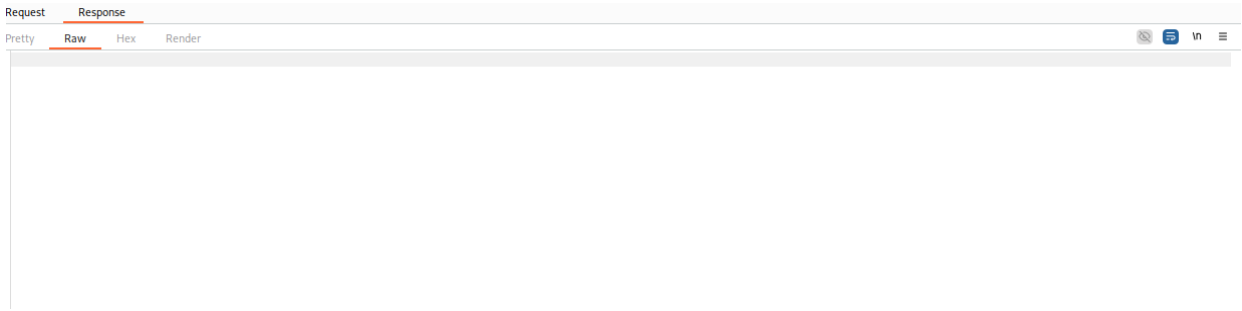


Here I did attack using intruder adding payload like null, test, symbols just to check the integrity of my code. So at start the status code is 200 where manipulation wasn't done.



But later where I added the random values the status code becomes empty and it start showing ticks on error column which proved that the next.js framework is working fine due to which it’s not sending any response.





Findings:

- Login endpoint only accepts POST requests; GET requests returned 405 Method Not Allowed.
- CSRF tokens are implemented and verified for POST requests.
- Malformed query parameters are safely ignored and do not expose sensitive data.
- Response headers and behavior indicate proper rate limiting and session enforcement.

Phase 4: Manual Analysis / Post-Exploitation

Focus: Admin-only access, input validation, and session management.

Step 1: Access Control Verification

- Verified that all endpoints require authentication.
- Attempting to access /login or /admin without authentication redirected to login or returned 403/405.

Step 2: Input Validation

- Tested login and other input fields with empty, null, and boundary payloads (Sniper mode concept).
- Observed no errors, stack traces, or data leakage.

Step 3: Session and Token Management

- Confirmed session cookies expire correctly upon logout.
- Tokens cannot be reused, and role enforcement is correct.

Step 4: Privilege Escalation

- Application is single-role (admin only); horizontal or vertical escalation is not applicable.
- Verified admin-only endpoints are protected and inaccessible without valid credentials.

Step 5: Security Headers and Best Practices

- HSTS is enforced (Strict-Transport-Security).

- HTTPS is correctly configured.
- No sensitive headers or verbose error messages exposed.

1. Tools Summary

Tool	Purpose
Nmap	Network and port enumeration
Nikto	Web server misconfiguration scanning
Gobuster	Directory and endpoint enumeration
Hydra	Brute-force login verification
Burp Suite	Manual input validation, endpoint testing, Sniper attack simulation

2. Results and Findings

- **Authentication:** Correctly enforced; login only via POST.
- **Authorization:** Admin-only access verified; no privilege escalation possible.
- **Session Management:** Sessions expire properly; tokens validated.
- **Input Validation:** All tested payloads handled safely.
- **Server Security:** HTTPS enforced; HSTS enabled; minor missing headers (X-Frame-Options, X-Content-Type-Options).
- **Directory & Endpoint Enumeration:** No sensitive hidden endpoints discovered.
- **Brute Force Resistance:** Login endpoint correctly rejects incorrect credentials.

Overall Security Posture: Strong. Minor improvements recommended for missing security headers.

3. Recommendations

1. Add X-Frame-Options header to prevent clickjacking.
2. Add X-Content-Type-Options: nosniff to enforce MIME type security.

3. Continue monitoring for updates to Vercel or Next.js deployments to maintain security.

Finding	Severity	Action
Missing X-Frame-Options	Low–Medium	Add header
Missing X-Content-Type-Options	Low	Add header
CORS wildcard	Low	Review APIs
Vercel / Next.js headers	Info	Ignore
Internal IP exposure	Info	Ignore
WAF mitigation	Good	Keep enabled
Missing Strict-Transport-Security header is not present in HTTPS responses	Medium	Add CSP in header

4. Conclusion

The admin-only web application is well-configured, with strong access controls, session management, and input validation. No critical vulnerabilities were identified during testing. The application is considered **secure for production use**, with minor recommendations to enhance header security.